

O Poder do JWT

JSON Web Token: A forma moderna e segura de autenticar usuários em APIs REST.

O que é JWT?

O **JSON Web Token (JWT)** é um padrão aberto (RFC 7519) que define uma maneira compacta e autossuficiente de transmitir informações com segurança entre as partes como um objeto JSON.

Em palavras simples, é como um "**Crachá Digital**". Uma vez que o usuário faz login, o servidor cria esse crachá e o entrega ao navegador. A partir daí, o usuário mostra esse crachá para entrar em áreas restritas sem precisar digitar a senha novamente.

Vantagens

- ✓ **Stateless:** O servidor não precisa guardar a sessão na memória. O próprio token tem tudo.
- ✓ **Compacto:** Pode ser enviado via URL, POST ou Headers HTTP (o mais comum).
- ✓ **Seguro:** Assinado digitalmente, não pode ser alterado por terceiros.

Anatomia do JWT

Um JWT é formado por três partes divididas por pontos:

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.
eyJpZCI6MSwicGFwZWwiOiJhZG1pbilzImhhdCI6MTYyMjU1NTE3OH0.
SflKxwRJSMeKKF2QT4fwpMeJf36POk6yJV_adQssw5c

■ Header ■ Payload (Dados) ■ Assinatura

A Estrutura

- 1. Header (Cabeçalho):** Define o tipo do token (JWT) e o algoritmo de criptografia usado (geralmente HMAC SHA256 ou RSA).
- 2. Payload (Corpo):** Contém as afirmações (claims). Aqui colocamos dados do usuário, como o ID e se ele é 'admin' ou 'cliente'. *Atenção: Não coloque senhas aqui, pois esta parte pode ser lida por qualquer um!*
- 3. Assinatura (Signature):** A mágica acontece aqui. O servidor junta o Header, o Payload e uma **Chave Secreta** (que só o servidor sabe) para criar uma assinatura. Se alguém alterar o Payload, a assinatura fica inválida.

Como é usado?

Passo 1: O cliente envia Email e Senha (POST /login).

Passo 2: O servidor valida no banco. Se ok, gera o JWT e devolve.

Passo 3: O cliente guarda o JWT (ex: LocalStorage).

Passo 4: Em requisições futuras, o cliente envia o JWT no cabeçalho HTTP:

Authorization: Bearer <token>.

Passo 5: O servidor valida a assinatura. Se válido, libera o acesso.

Pronto para o Projeto!

No nosso projeto **Sabor Digital**, usamos JWT para diferenciar o acesso de *Admins* (podem criar e excluir produtos) de *Clientes* (só visualizam o cardápio).

[Voltar ao Topo](#)